

Cerebro for GRC Teams

Your Daily Compliance Operations Guide

Writer Security & Compliance

Updated November 6, 2025

What This Guide Covers

- ▶ How Cerebro fits into your daily compliance workflows
- ▶ Key tasks: control monitoring, evidence collection, audit preparation
- ▶ Where to find what you need without technical expertise
- ▶ Real scenarios from risk assessment to auditor delivery

What Cerebro Does for You

- ▶ **Continuous control monitoring:** automated tests replace manual sampling
- ▶ **Evidence automation:** screenshots and reports generated for you
- ▶ **Audit-ready packages:** immutable records with cryptographic integrity
- ▶ **Policy compliance tracking:** attestations and acknowledgments in one place

For Your Day-to-Day

- ▶ Less time gathering evidence
- ▶ More time analyzing risk
- ▶ Confidence in audit readiness

Where Cerebro Replaces Manual Work

Before Cerebro:

- ▶ Screenshot every control test, organize in folders
- ▶ Email security team asking for system configurations
- ▶ Spreadsheet tracking which employees signed which policies
- ▶ Panic mode two weeks before audit starts

With Cerebro:

- ▶ Evidence collected automatically, ready when auditors ask
- ▶ Real-time visibility into which controls pass or fail
- ▶ Policy attestations tracked with cryptographic signatures
- ▶ Audit packages generated in minutes, not days

Monday Morning: Weekly Control Review

What You Need to Know: Are we still in compliance?

Where to Look:

- ▶ Dashboard at `/analytics/executive` shows overall compliance posture
- ▶ Control test results at `/compliance/controls` with pass/fail status
- ▶ Failed controls highlighted with remediation owners assigned

What to Do:

- ▶ Review any newly failed controls—are they real issues or false positives?
- ▶ Follow up with assigned owners on overdue remediation tasks
- ▶ Note trends: are specific control families degrading?

Daily Task: Reviewing Control Exceptions

Scenario: A team requests an exception for a failed control

Your Workflow:

1. Navigate to /compliance/controls and find the failing control
2. Review the control test details: what specifically is failing?
3. Click "Create Exception" and document:
 - ▶ Business justification
 - ▶ Compensating controls in place
 - ▶ Expiration date (30/60/90 days)
 - ▶ Required approvals (your signature + CISO)
4. Exception is logged with timestamp and cannot be altered later

Audit Value: Auditors see documented risk acceptance with proper approval chain

Mid-Week: Evidence Collection Check

What You're Monitoring: Is evidence flowing properly?

Key Indicators at /compliance/evidence:

- ▶ **Freshness:** Last collection timestamp per control
- ▶ **Coverage:** Which controls have current evidence vs. stale
- ▶ **Health:** Any collection failures requiring IT follow-up

Common Issues:

- ▶ Integration disconnected: coordinate with IT to reconnect (e.g., Okta, AWS)
- ▶ Manual evidence needed: assign task to control owner with due date
- ▶ Policy updates required: flag for next policy review cycle

Friday Afternoon: Policy Attestation Status

Goal: Ensure employees acknowledge required policies

Your Dashboard View at /compliance/policies:

- ▶ Overall attestation rate: 94% of employees current
- ▶ Overdue attestations: 12 employees need to sign acceptable use policy
- ▶ Department breakdown: Engineering 98%, Sales 87%

Actions:

- ▶ Send reminder email to overdue employees (one-click from dashboard)
- ▶ Escalate to department managers if 7+ days overdue
- ▶ Review new hire attestation completion: should be 100% within first week

Four Weeks Before Audit: Readiness Check

Use the **Audit Readiness Report** at `/compliance/audit-readiness`:

- ▶ **Control coverage:** 87 of 90 SOC2 controls have current evidence
- ▶ **Evidence gaps:** 3 controls need manual evidence collection
- ▶ **Policy status:** All policies up-to-date, 96% employee attestation
- ▶ **Exception review:** 4 active exceptions, all properly documented

Pre-Audit Checklist:

- ▶ Close out any overdue remediation tasks or document as exceptions
- ▶ Ensure all manual evidence is collected and uploaded
- ▶ Review control test history for any suspicious patterns
- ▶ Generate preliminary evidence bundle for internal review

During Audit: Request List Management

Scenario: Auditor sends request list with 45 items

Cerebro Workflow:

1. Upload request list to /compliance/audit-workflow
2. System auto-matches requests to existing evidence (30 items matched)
3. Remaining 15 items auto-assigned to control owners
4. Track completion: 42/45 complete, 3 in progress

Benefits:

- ▶ No more "who's working on what?" confusion
- ▶ Evidence delivered in auditor-friendly format
- ▶ Chain of custody preserved for each artifact
- ▶ Typical audit response time: 2-3 days vs. 2 weeks

Evidence Bundle Generation

What Auditors Receive:

Bundle Contents (generated via `/compliance/evidence/export`):

- ▶ Manifest file listing all included evidence with timestamps
- ▶ Control test results with pass/fail status and screenshots
- ▶ Policy documents with version history and attestation records
- ▶ System configuration snapshots (IAM, security groups, MFA status)
- ▶ Digital signatures proving evidence hasn't been tampered with

Format: ZIP file with PDF report + JSON data for auditor's analysis tools

Auditor Benefits:

- ▶ Clear evidence organization matching their testing procedures
- ▶ Cryptographic verification of evidence integrity
- ▶ Point-in-time snapshots for any date in audit period

Scenario: Executive Risk Briefing

Request: CFO needs compliance status for board meeting

Your 5-Minute Workflow:

1. Navigate to /analytics/executive
2. Export executive summary showing:
 - ▶ Overall compliance score: 94/100
 - ▶ Control pass rate: 92% (83 passing, 7 failing)
 - ▶ Recent improvements: MFA compliance 78% → 96%
 - ▶ Open risks: 2 high-priority findings under remediation
3. Add narrative context in provided template
4. Export as board-ready PDF with charts

Result: Professional summary without technical jargon, audit-trail backed numbers

Scenario: Vendor Risk Assessment

Context: Security team flags a critical vendor; GRC needs risk assessment

Cerebro Helps You Understand:

- ▶ **At /security-center/vendors:** vendor profile with risk rating
- ▶ **What data they access:** linked to data classification and systems
- ▶ **Compliance status:** SOC2/ISO27001 report status and expiration
- ▶ **Incident history:** any prior security events involving this vendor

Your Assessment:

- ▶ Document risk level with supporting evidence
- ▶ Assign compensating controls (e.g., enhanced monitoring)
- ▶ Set review date for next assessment
- ▶ All documentation auto-captured for audit trail

Scenario: Failed Control Investigation

Alert: Automated control test fails—"Privileged accounts without MFA"

Your Investigation Path:

1. Click alert to see control test details
2. Review affected accounts: 3 admin accounts flagged
3. Check if legitimate: are these service accounts or human users?
4. Coordinate remediation:
 - ▶ Human accounts: IT enables MFA within 24 hours
 - ▶ Service accounts: document exception with compensating controls
5. Re-run control test to confirm remediation

Audit Value: Complete timeline of detection → investigation → resolution

How Often Should I Check Cerebro?

Daily:

- ▶ Quick dashboard review (2 minutes): any new critical failures?
- ▶ Policy attestation reminders: any urgent overdue items?

Weekly:

- ▶ Control test results: trends and patterns
- ▶ Evidence collection health: any integration issues?
- ▶ Exception review: approaching expiration dates?

Monthly:

- ▶ Executive summary report for leadership
- ▶ Control effectiveness review with security team
- ▶ Policy review cycle: any updates needed?

What If I Don't Understand a Technical Finding?

Translation Help Built-In:

- ▶ Each control has "**Business Impact**" section explaining why it matters
- ▶ "**Recommended Action**" provides non-technical remediation guidance
- ▶ **Ask the agent:** conversational interface at `/agents/chat`
 - ▶ Ask: "Explain this IAM finding in simple terms"
 - ▶ Agent provides context without requiring security expertise

When to Escalate:

- ▶ You're unsure if a control failure is acceptable: consult CISO
- ▶ Remediation requires technical work: assign to security engineering
- ▶ Auditor asks technical questions: coordinate with security team

How Do I Trust the Data?

Built-In Integrity Guarantees:

- ▶ **Immutable audit logs:** once recorded, evidence cannot be altered
- ▶ **Cryptographic signatures:** each evidence artifact is digitally signed
- ▶ **Chain of custody:** timestamp and source system for every record
- ▶ **Point-in-time queries:** retrieve exact state from any past date

Auditor Verification:

- ▶ Auditors can verify signatures independently
- ▶ SQL query engine allows auditors to re-run tests themselves
- ▶ Evidence bundles include manifest with checksums

Your Confidence: When you present evidence, it's legally defensible

Working with Other Teams

With Security Engineering:

- ▶ They configure control tests and integrations
- ▶ You interpret results and manage exceptions
- ▶ Shared view of control effectiveness and risk posture

With Internal Audit:

- ▶ Cerebro feeds their continuous audit program
- ▶ Evidence you collect serves their testing procedures
- ▶ Aligned control frameworks (SOC2, ISO27001)

With External Auditors:

- ▶ Read-only portal access at `/auditor-portal`
- ▶ Evidence bundles match their request format
- ▶ Direct access reduces back-and-forth emails

Cerebro in Your Compliance Calendar

Quarterly Board Reporting:

- ▶ Export executive summary with risk trends
- ▶ Highlight control improvements and investments

Annual SOC2 / ISO27001 Audit:

- ▶ 4 weeks before: readiness assessment
- ▶ During: request list workflow and evidence delivery
- ▶ After: maintain continuous evidence for interim monitoring

Ad-Hoc Customer Questionnaires:

- ▶ Search evidence library for specific controls
- ▶ Generate snapshots for customer-specific date ranges
- ▶ Package responses with supporting documentation

Support Resources

Within Cerebro:

- ▶ **Help icon** (?) on every page with context-specific guidance
- ▶ **Agent assistant** at /agents/chat for plain-English questions
- ▶ **Audit trail viewer**: understand how any number was calculated

Internal Support:

- ▶ Slack: #cerebro-grc for GRC-specific questions
- ▶ Email: compliance-ops@writer.com
- ▶ Office hours: Wednesdays 2-3pm with GRC and security engineering

Documentation:

- ▶ User guide: /docs/compliance-features
- ▶ Framework mapping: /docs/framework-guides
- ▶ Video tutorials: internal knowledge base

Training and Onboarding

For New GRC Team Members:

1. 30-minute overview session (this presentation!)
2. Hands-on tour: controls, evidence, policies, audit workflow
3. Shadow experienced team member during next audit cycle
4. Independent access after first week

Recommended Learning Path:

- ▶ Week 1: Dashboard navigation and reading control results
- ▶ Week 2: Evidence review and policy attestation management
- ▶ Week 3: Exception workflow and risk assessment
- ▶ Week 4: Audit preparation and bundle generation

What Makes Cerebro Different

- ▶ **Continuous, not point-in-time:** always audit-ready, not just during audits
- ▶ **Automated evidence collection:** your time shifts from gathering to analyzing
- ▶ **Legally defensible:** immutable records with cryptographic integrity
- ▶ **Built for GRC workflows:** not a security tool with compliance bolted on

Your Day-to-Day Impact

Time Savings:

- ▶ 70% reduction in audit preparation time
- ▶ 85% of evidence collection automated
- ▶ 2-3 day audit response time vs. 2 weeks

Risk Posture:

- ▶ Real-time visibility into control effectiveness
- ▶ Proactive exception management before auditor findings
- ▶ Confidence in presenting compliance status to executives

Audit Outcomes:

- ▶ Faster audits with fewer follow-up questions
- ▶ Stronger evidence supporting control design and effectiveness
- ▶ Better auditor relationships through streamlined collaboration

Next Steps

This Week:

- ▶ Get your Cerebro account credentials from IT
- ▶ Take the 15-minute dashboard tour
- ▶ Review current control test results and ask questions

This Month:

- ▶ Shadow a complete workflow (exception request or evidence export)
- ▶ Join weekly GRC sync where we review Cerebro metrics
- ▶ Identify one manual process to automate with Cerebro

This Quarter:

- ▶ Lead audit preparation using Cerebro workflows
- ▶ Provide feedback on features that would help GRC team
- ▶ Train new team members on Cerebro usage

Questions & Contact

Questions?

Reach the team:

Slack: #cerebro-grc

Email: compliance-ops@writer.com

Office Hours: Wednesdays 2-3pm